Walking An Application

Exploring The Website

your role when reviewing a website or web application is to discover features that could potentially be vulnerable and attempt to exploit them to assess whether or not they are.

An excellent place to start is just with your browser exploring the website and noting down the individual pages/areas/features with a summary for each one.

An example site review for the Acme IT Support website would look something like this:

Feature	URL	Summary
Home Page	/	This page contains a summary of what Acme IT Support does with a company photo of their staff.
Latest News	/news	This page contains a list of recently published news articles by the company, and each news article has a link with an id number, i.e. /news/article?id=1
News Article	/news/article?id=1	Displays the individual news article. Some articles seem to be blocked and reserved for premium customers only.
Contact Page	/contact	This page contains a form for customers to contact the company. It contains name, email and message input fields and a send button.
Customers	/customers	This link redirects to /customers/login.
Customer Login	/customers/login	This page contains a login form with username and password fields.
Customer Signup	/customers/signup	This page contains a user-signup form that consists of a username, email, password and password confirmation input fields.
Customer Reset Password	/customers/reset	Password reset form with an email address input field.
Customer Dashboard	/customers	This page contains a list of the user's tickets submitted to the IT support company and a "Create Ticket" button.
Create Ticket	/customers/ticket/new	This page contains a form with a textbox for entering the IT issue and a file upload option to create an IT support ticket.
Customer Account	/customers/account	This page allows the user to edit their username, email and password.
Customer Logout	/customers/logout	This link logs the user out of the customer area.

Viewing The Page Source

The page source is the human-readable code returned to our browser/client from the web server each time we make a request.

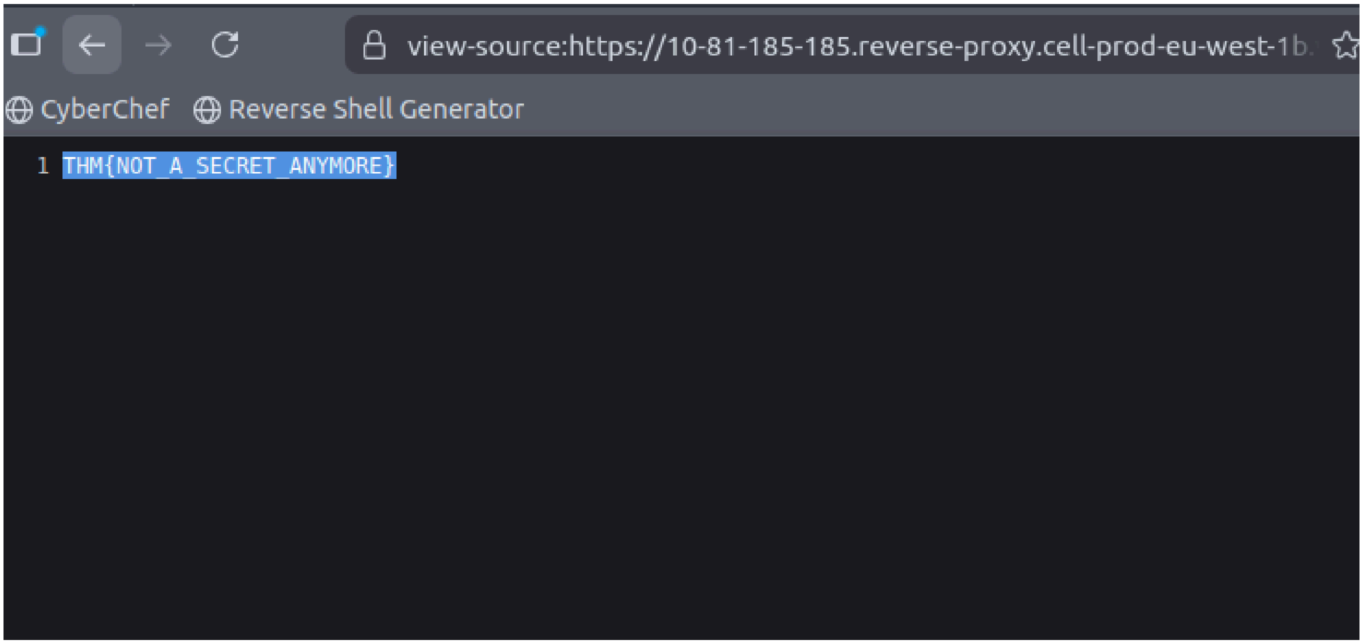
The returned code is made up of HTML (HyperText Markup Language), CSS (Cascading Style Sheets) and JavaScript, and it's what tells our browser what content to display, how to show it and adds an element of interactivity with JavaScript.

viewing the page source can help us discover more information about the web application.

secret link flag:

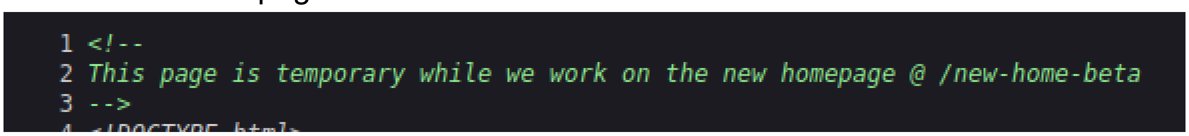
```
<!--
This page is temporary while we work on the new homepage @ /new-home-beta
-->
<!DOCTYPE html>
<html lang="en">
<head>
    <title>Acme IT Support - Home</title>
    <meta charset="utf-8">
    <meta http-equiv="X-UA-Compatible" content="IE=edge">
    <meta name="viewport" content="width=device-width, initial-scale=1">
        <link rel="stylesheet" href="https://pro.fontawesome.com/releases/v5.12.0/css/all.css" integrity="sha384-ekOryaXPbeCpWQNxMwS
        <link rel="stylesheet" href="/assets/bootstrap.min.css">
    <link rel="stylesheet" href="/assets/style.css">
</head>
<body>
    <nav class="navbar navbar-inverse navbar-fixed-top">
        <div class="container">
            <div class="navbar-header">
                <button type="button" class="navbar-toggle collapsed" data-toggle="collapse" data-target="#navbar" aria-expanded="fa
                    <span class="sr-only">Toggle navigation</span>
                    <span class="icon-bar"></span>
                    <span class="icon-bar"></span>
                    <span class="icon-bar"></span>
                </button>
                <a class="navbar-brand" href="#">Acme IT Support</a>
            </div>
            <div id="navbar" class="collapse navbar-collapse">
                <ul class="nav navbar-nav">
                    <li class="active"><a href="/">Home</a></li>
                    <li><a href="/news">News</a></li>
                    <li><a href="/contact">Contact</a></li>
                    <li><a href="/customers">Customers</a></li>
                </ul>
            </div><!--/.nav-collapse -->
        </div>
    </nav><div class="container" style="padding-top:60px">
    <h1 class="text-center">Acme IT Support</h1>
    <div class="row">
        <div class="col-md-8 col-md-offset-2 text-center">
            <img src="/assets/staff.png">
            <p class="welcome-msg">Our dedicated staff are ready <a href="/secret-page">to</a> assist you with your IT problems.</p>
        </div>
    </div>
</div>
<script src="/assets/jquery.min.js"></script>
<script src="/assets/bootstrap.min.js"></script>
<script src="/assets/site.js"></script>
</body>
```

I can see different pages of the website and also see a secret page link which got me a flag:

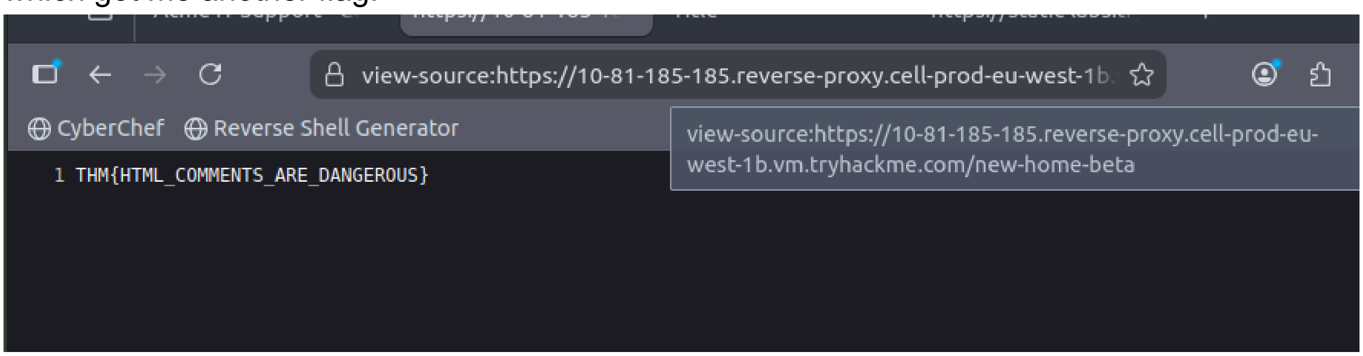


Comment flag:

I then went to the page in this comment:

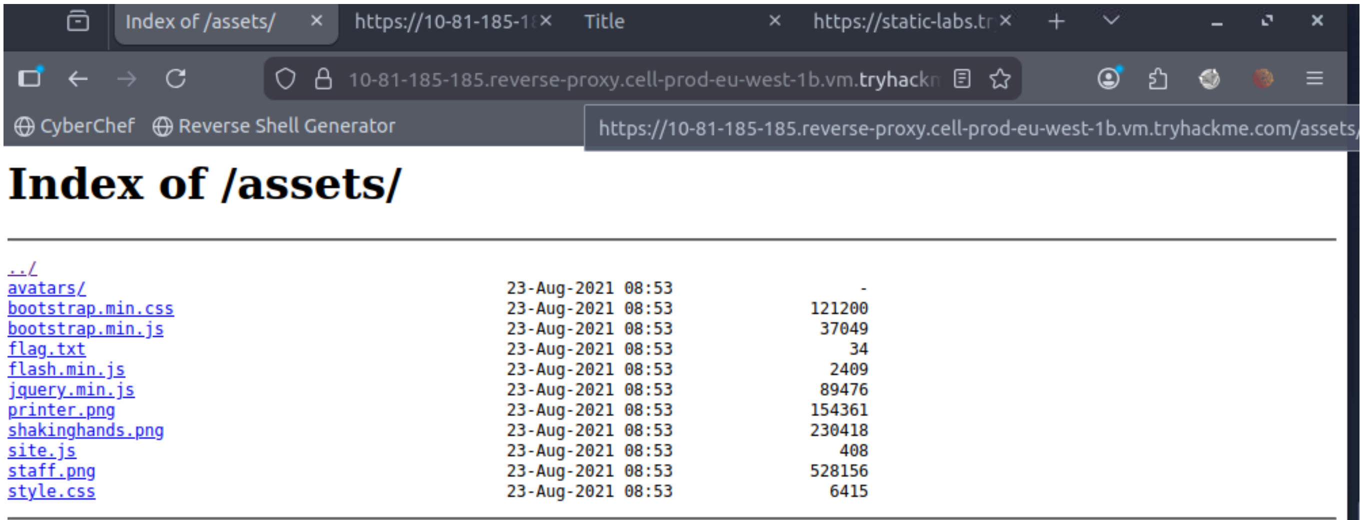


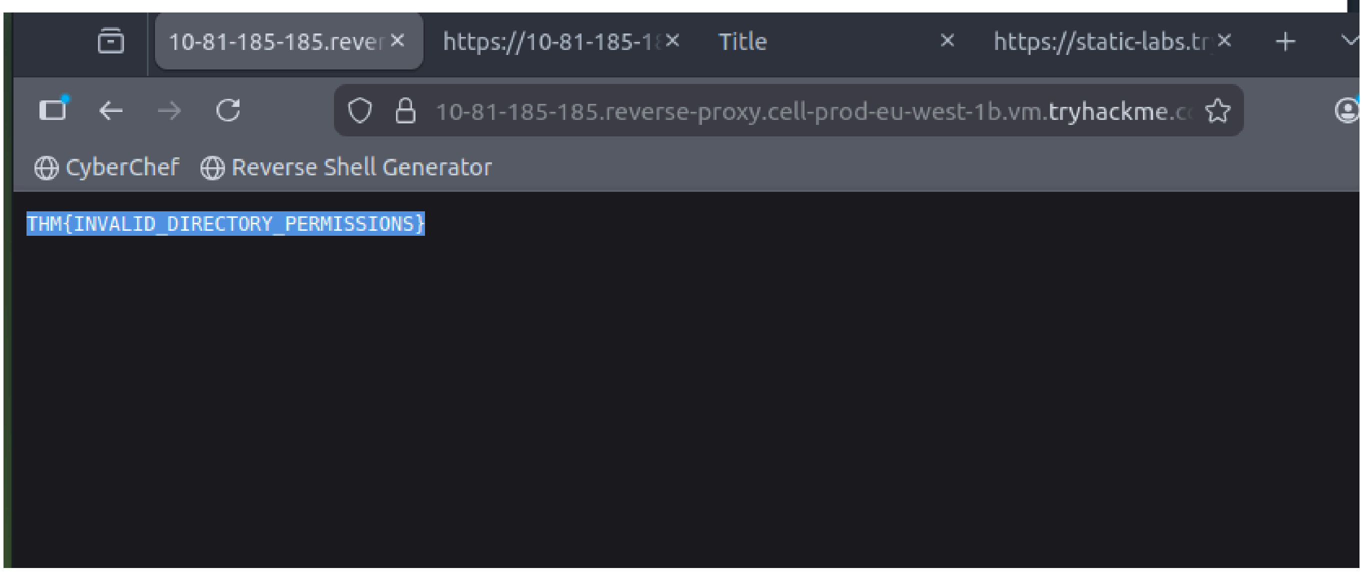
which got me another flag:



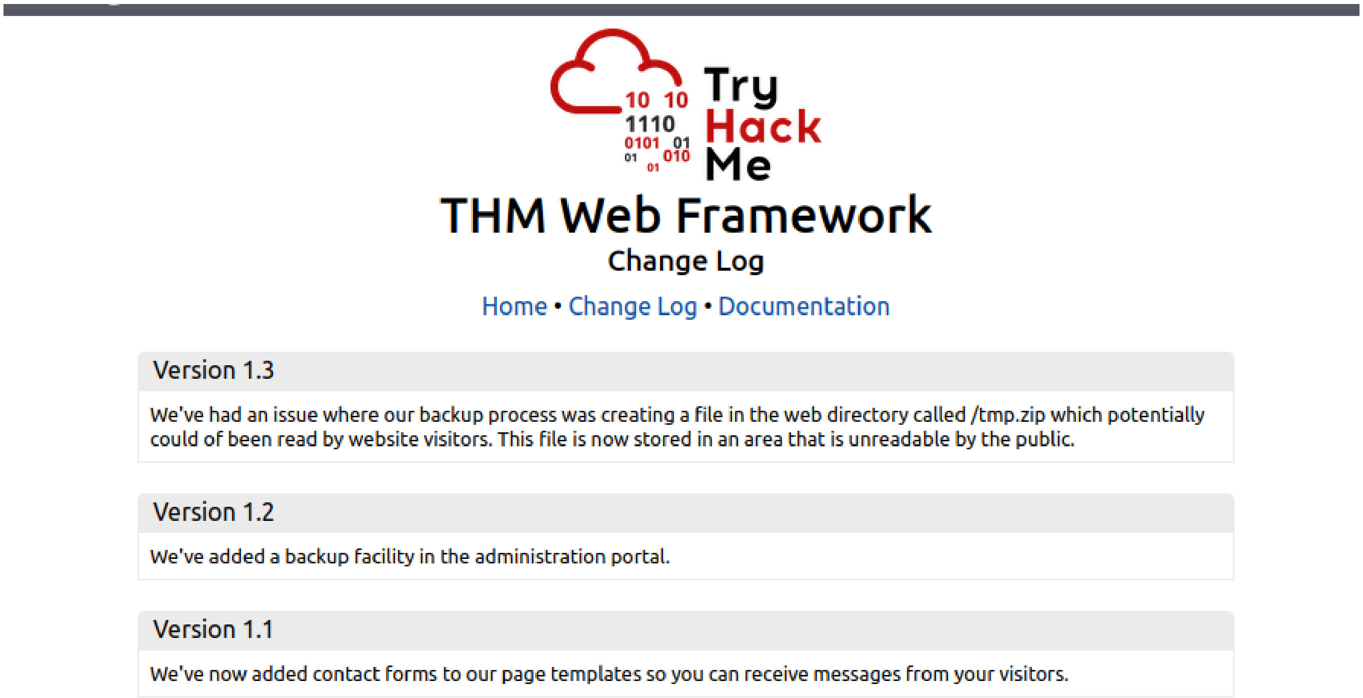
directory listing flag:

i found a /assets page and this listed off the directories of the site and found flag.txt

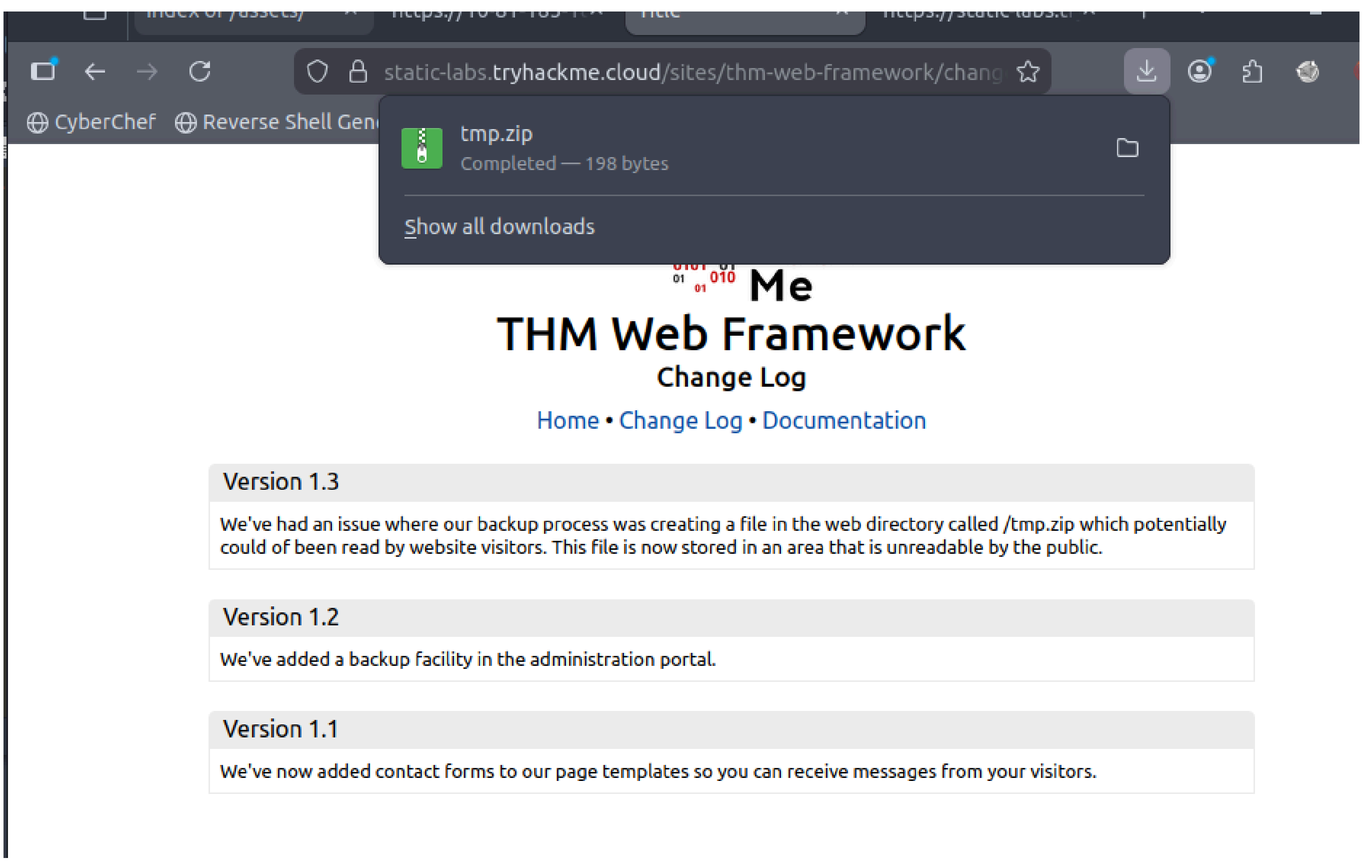




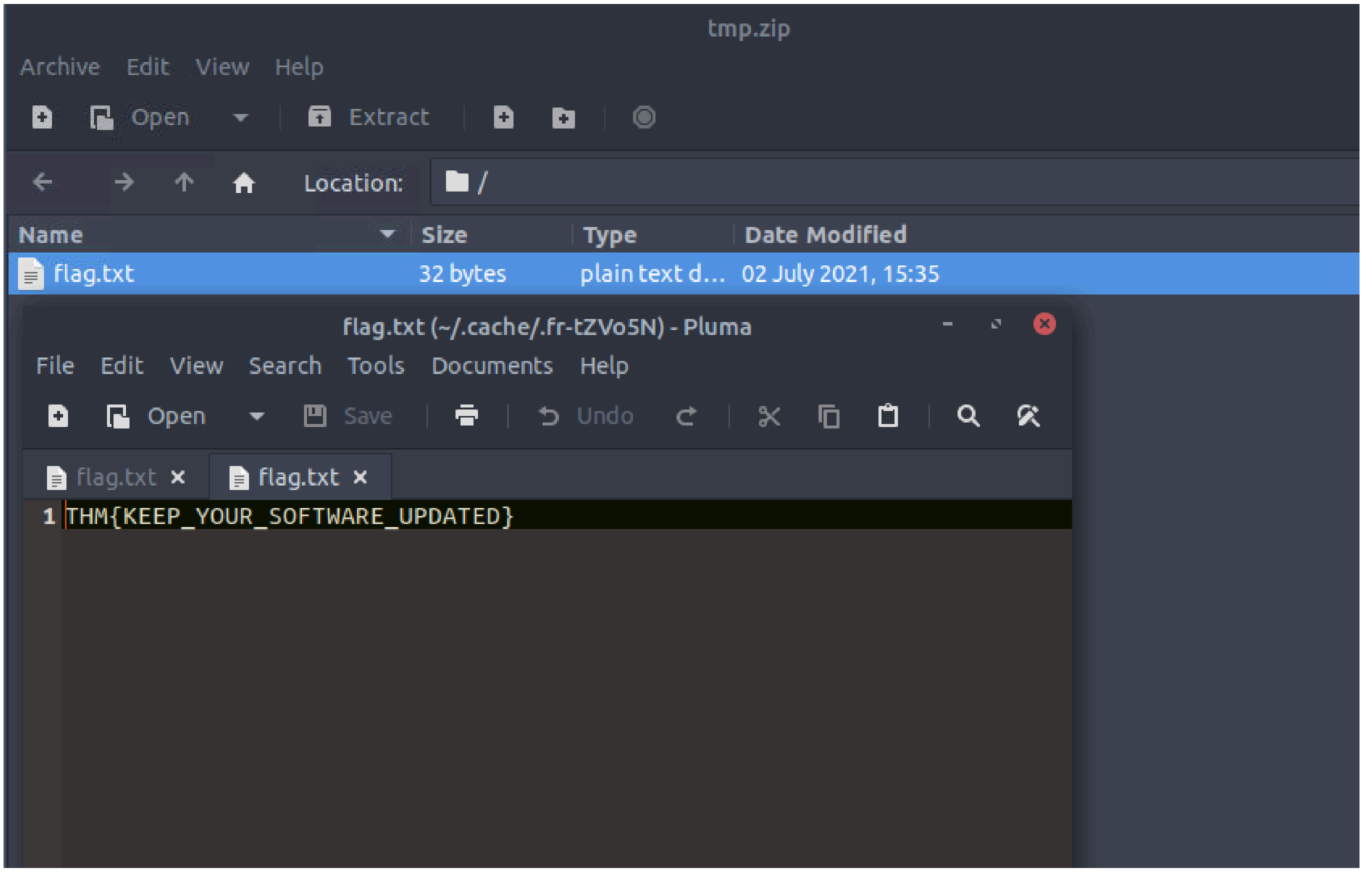
Framework flag:



version 1.3 tells us what vulnerability was patched meaning 1.2 is vulnerable which the site is on is vulnerable. It tells us exactly what its vulnerable to which allowed me to download a zip file :



I then opened up the file to find a flag.txt

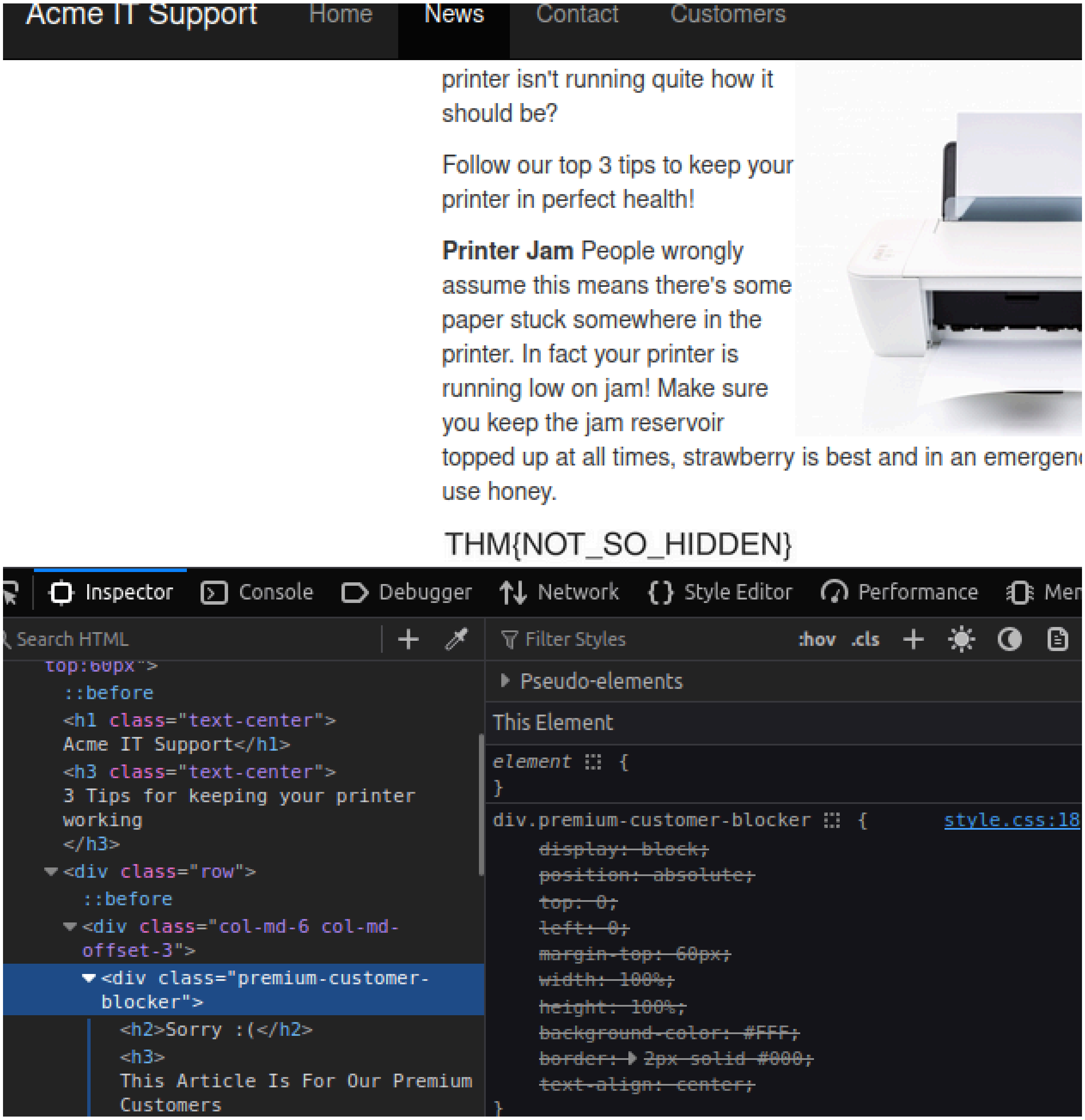


Developer Tools Inspector

Inspector

Element inspector assists us with this by providing us with a live representation of what is currently on the website.

As well as viewing this live view, we can also edit and interact with the page elements, which is helpful for web developers to debug issues.

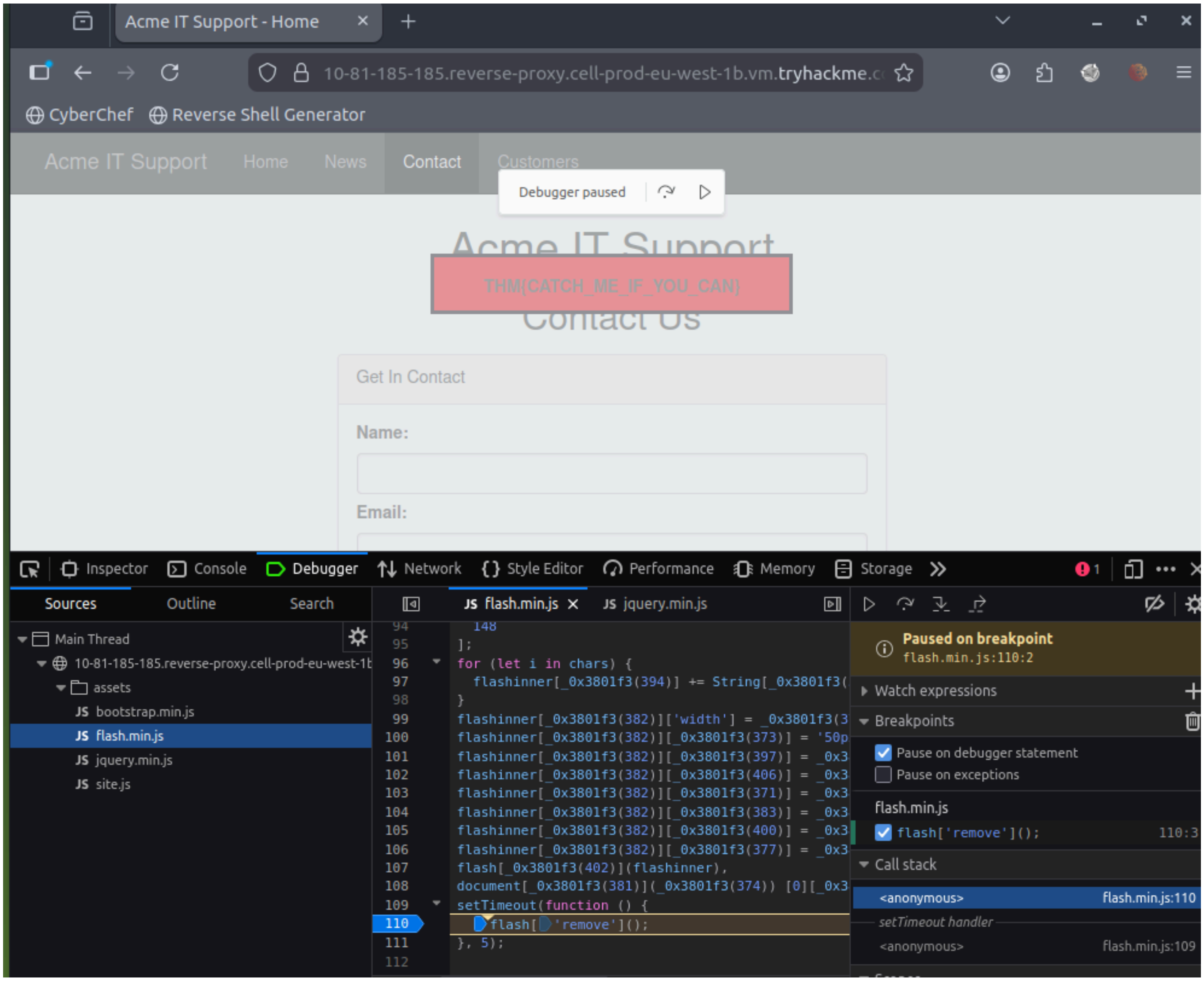


in dev tools i inspected the premium customer blocker and turned off all the elements to view the contents behind the blocker.

Developer Tools - Debugger

This panel in the developer tools is intended for debugging JavaScript, and again is an excellent feature for web developers wanting to work out why something might not be working. But as penetration testers, it gives us the option of digging deep into the JavaScript code.

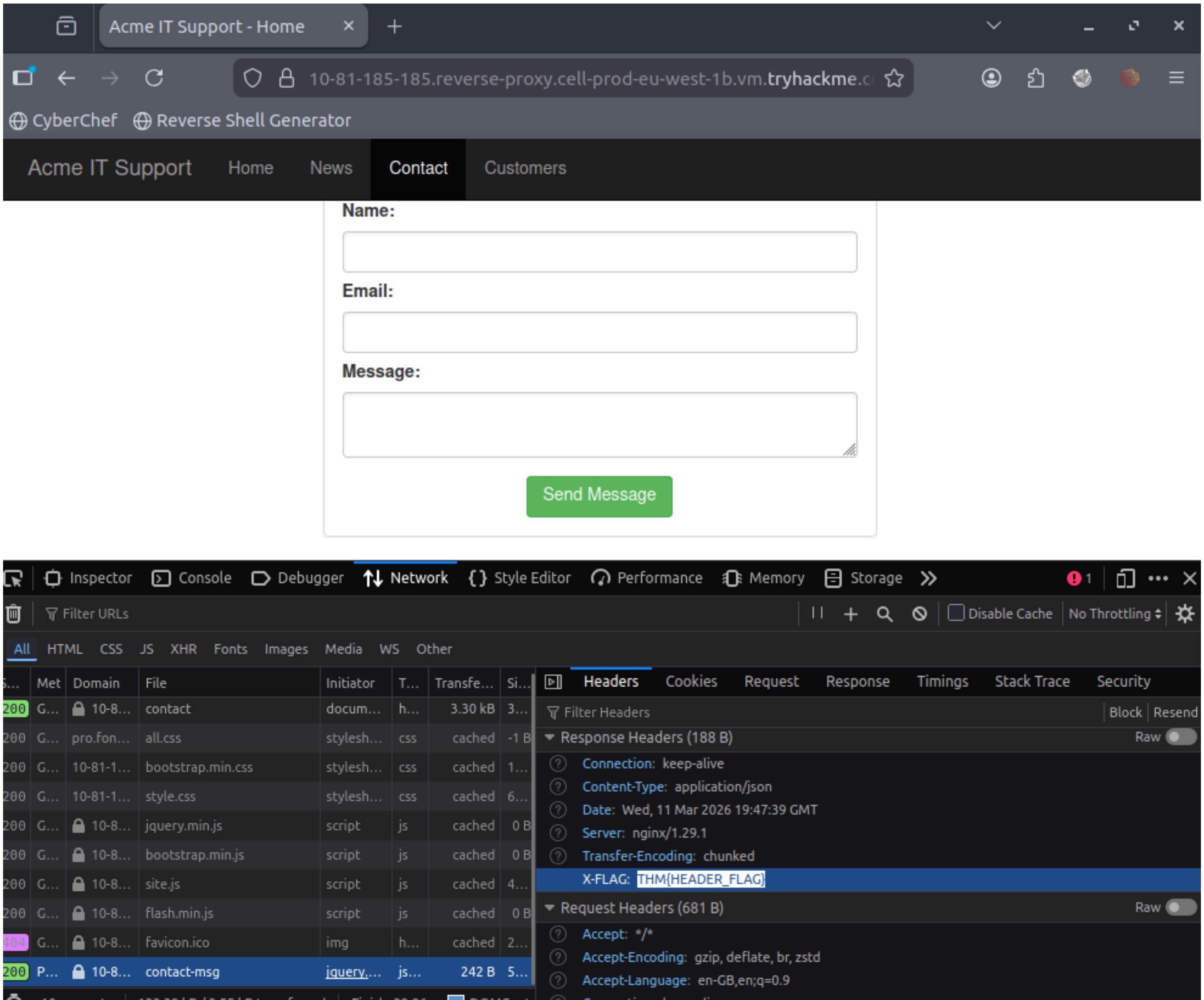
I went into debugger on the content page after noticing a little red flash everytime this page is loaded. within the debugger there was a flash.min.js script and i found the flash remove and inserted a break point so it would pause when that flash comes up allowing me to view it

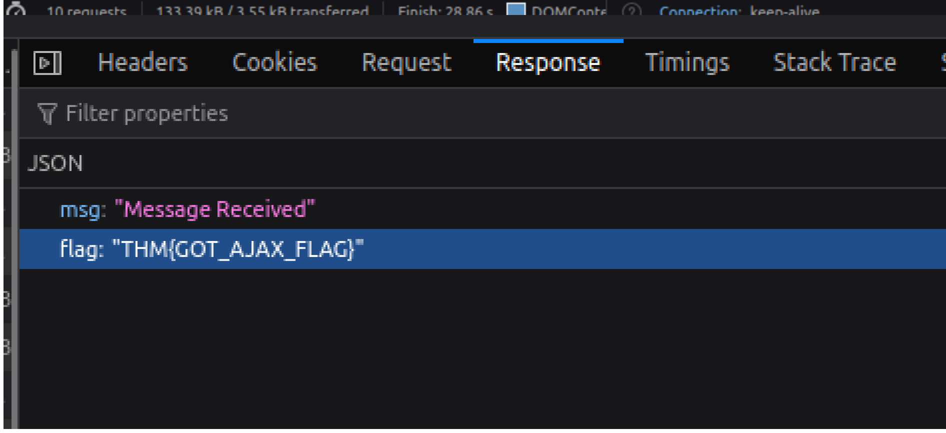


Developer Tools - Network

The network tab on the developer tools can be used to keep track of every external request a webpage makes. If you click on the Network tab and then refresh the page, you'll see all the files the page is requesting.

I went to the contacts page and opened the network tab to see the requests, I then put in a request by submitting a message to the page which displayed the contact.msg request I opened that up and found the flag under the response section.


Acme IT Support - Home
10-81-185-185.reverse-proxy.cell-prod-eu-west-1b.vm.tryhackme.c
CyberChef
Reverse Shell Generator
Acme IT Support
Home
News
Contact
Customers
Name:
Email:
Message:
Send Message
Inspector
Console
Debugger
Network
Style Editor
Performance
Memory
Storage
Filter URLs
Disable Cache
No Throttling
All HTML CSS JS XHR Fonts Images Media WS Other
contact
all.css
bootstrap.min.css
style.css
jquery.min.js
bootstrap.min.js
site.js
flash.min.js
favicon.ico
contact-msg
Headers
Cookies
Request
Response
Timings
Stack Trace
Security
Filter Headers
Response Headers (188 B)
Connection: keep-alive
Content-Type: application/json
Date: Wed, 11 Mar 2026 19:47:39 GMT
Server: nginx/1.29.1
Transfer-Encoding: chunked
X-FLAG: THM{HEADER_FLAG}
Request Headers (681 B)
Accept: */*
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: en-GB,en;q=0.9


Headers
Cookies
Request
Response
Timings
Stack Trace
Filter properties
JSON
msg: "Message Received"
flag: "THM{GOT_AJAX_FLAG}"